



EKOPARTY MIAMI

THREAT INTELLIGENCE 101

*From Reactive to
Predictive Approach*

Daniel Pérez

CTI · Sadvivor

June 22, 2026

About.ME

A	Star Wars fanatic
B	Topics I follow: Threat Intelligence - Ransomware.
C	Roles I have held:
D	SOC Analyst (L1, L2)
E	Phishing Analyst
F	Threat Intelligence – Incident Response
G	Criminal Intelligence (Information Gathering) – Counter Intelligence (State of Argentina)
H	Hobbies: Drones, 3D Printing, Growing my own Mushrooms (Edible), Distilling my own GIN.



Certified Incident Responder



Certified Threat Hunter Professional



01	Why CTI today? · Myth vs reality of the adversary	2'
02	Fundamentals · Pipeline · Cycle · PIRs	4'
03	Threat Intelligence Sources	3'
04	Frameworks (Kill Chain · Diamond · ATT&CK · Pyramid of Pain)	11'
05	From reactive to predictive · CTI Maturity · Metrics	4'
06	Case Study: "You can run, but you can't hide"	5'
07	Closing, takeaways and Q&A	1'

Why CTI today?

The terrain accelerated. The asymmetry did not.

THE TERRAIN ACCELERATED

62 min

Average eCrime breakout time — the fastest: 2 min 7 s. (CrowdStrike 2024)

75 %

Of intrusions are malware-free: valid credentials and legitimate tools.

\$4.88M

Average global cost of a breach — all-time record. (IBM 2024)

10 days

Median dwell time: the attacker lives inside before being detected. (Mandiant 2024)

THE ASYMMETRY DID NOT CHANGE

ATTACKER

Chooses the moment, vector and target.

ATTACKER

One open door is enough.

ATTACKER

Iterates cheaply, fails at no cost.

ATTACKER

Knows their victim.

DEFENDER

Covers everything, all the time.

DEFENDER

Has to close them all.

DEFENDER

Every false positive costs hours.

DEFENDER

Do they know their adversary?

What is CTI NOT?

Three myths we kill before moving on.

It is NOT an IOC feed

A feed without context is expensive noise. Intelligence begins when you ask: does this affect me?

It is NOT a dashboard of actors

Knowing the names does not defend you. Knowing the TTPs they use against the industry, and where they hit you, does.

It is NOT attribution

Knowing who attacked is a nice-to-have. Knowing how they are going to attack you and what decision you have to make tomorrow — that is CTI.



CTI is a process for answering questions that change decisions. If the intelligence we deliver cannot be translated into a decision, it is bad.

BLOCK 02 · FUNDAMENTALS

Data, Information, Intelligence — and the frameworks to turn it into a decision.

Data → Information → Intelligence

INTELLIGENCE

Actionable analysis for a decision-maker

TIMELY

RELEVANT

ACCURATE

ACTIONABLE

INFORMATION

Processed data with context.

DATA

Hashes, IPs, raw logs without context.

Me estas diciendo que un feed de IOCs es CTI?

Dilo una vez mas, te desafio

Cyber Threat Intelligence

Cyber Threat Intelligence is the process of collecting, processing, analyzing and disseminating information about adversaries — so that defenders make informed decisions.

SANS Institute · FOR578: Cyber Threat Intelligence

Known / Unknown: The Rumsfeld model

KNOWN KNOWNS

01

Operational reality

What we know we know.

SCENARIO

IT uses authorized ScreenConnect. LockBit, Akira and Medusa abuse AnyDesk, Atera and SimpleHelp — signed, allowlisted, invisible to your EDR.

This is where the reactive SOC lives.

KNOWN UNKNOWNNS

02

Strategic uncertainty

We know there are things we do not know.

SCENARIO

Infostealers (Lumma, Redline) capture RMM tokens every day. Your technician's ScreenConnect cookie may be for sale on Russian Market right now. They don't hack — they buy the key.

This is where PIRs and threat hunting live.

UNKNOWN UNKNOWNNS

03

Cyber black swan

What we do not know we do not know.

SCENARIO

Zero-day in the RMM server. (CVE-2024-1708/1709 in ScreenConnect, CVSS 10.0): auth bypass, ghost admins with no alerts. Black Basta and LockBit were already exploiting it before the patch.

This is where anticipatory intelligence lives.

The goal of CTI: move as much as possible from Unknown to Known — and accept what you cannot move.

Visualizing the Knowns / Unknowns

The same framework from the previous slide — applied to adversary modeling (Attack Trees).



The U.S. Secretary of Defense, during the Iraq War, popularized a risk management framework based on what we know and what we don't. The model became an essential tool for intelligence analysts to categorize risks and prioritize data collection.

Matriz de Conocimiento en Attack Trees

Known-Knowns aplicados a la construcción de árboles de ataque



"En la construcción de Attack Trees, los Known Knowns se representan con líneas sólidas, los Known Unknowns con líneas discontinuas (postulados) y los Unknown Unknowns son las áreas que requieren investigación adicional o pruebas de hipótesis."

Types of CTI: same data, different consumer

STRATEGIC

CONSUMER

CISO · Board · CEO

CONTENT

Trends, geopolitical risks, investment decisions.

HORIZON

Months → years

OPERATIONAL

CONSUMER

SOC Manager · IR Lead

CONTENT

Active campaigns, actors targeting the sector, IOCs and TTPs.

HORIZON

Weeks → months

TACTICAL

CONSUMER

SOC analyst · Threat hunter

CONTENT

Sigma/YARA rules, concrete IOCs, targeted hunts.

HORIZON

Hours → days

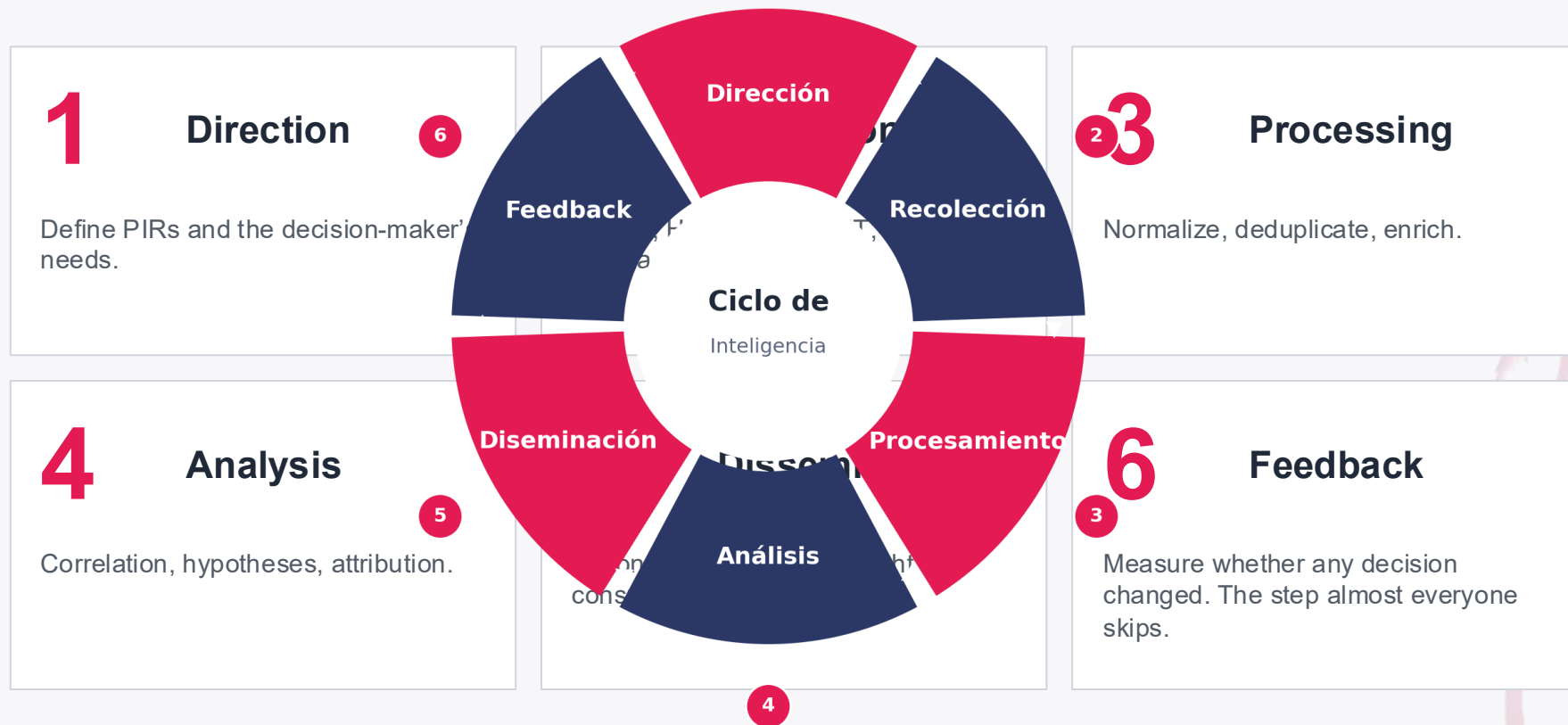
Same analysis, 3 deliverables

The problem is not the data, it is the storytelling .

EXECUTIVE	MANAGER	SPECIALIST
FORMAT 1 page · 1 chart THE QUESTION THEY CARE ABOUT <i>"What threatens our business and how much does it cost to mitigate?"</i>	FORMAT 1 report · 5 key points THE QUESTION THEY CARE ABOUT <i>Will this require a change to any Software or Hardware that we need to take out of production?</i>	FORMAT Full technical detail THE QUESTION THEY CARE ABOUT <i>"Give me the TTPs and IOCs to automate."</i>

Translate the technical into the language of the business: A CEO or a board of directors does not care about hashes, IP addresses or altered registry keys. Storytelling turns a boring "we detected malware X" into a striking "a cybercriminal group is trying to steal our customer database to extort us".

Intelligence cycle · 6 phases



PIR (Priority Intelligence Requirements)

WHAT A PIR IS

The concrete question the decision-maker needs CTI to answer in order to take a specific defensive action.

WHO WRITES IT

The decision-maker: CISO, SOC Manager, IR Lead. Not the analyst.

WHO ANSWERS IT

The CTI team.

ITS ROLE

Filters the noise of the infinite feed so only what matters gets through.



BAD PIR

"What are the new hacks on the internet?" — vague, infinite, triggers nothing.



PIRs are the questions the business needs CTI to answer. Without a PIR, everything else is noise.

PIRs · Priority Intelligence Requirements

The concrete questions from the decision-maker that CTI has to answer.

STRATEGIC	<i>Which actors with geopolitical motivation are targeting fintech in LATAM?</i>
OPERATIONAL	<i>What are the active ransomware TTPs against retail in the last 90 days?</i>
TACTICAL	<i>Which Lumma Stealer C2 indicators were reported this week?</i>

**You cannot defend everything, everywhere, all the time. PIRs = where to look first.
If your report does not answer a PIR, it is not intelligence. It is surplus information.**

BLOCK 03 · THREAT INTELLIGENCE SOURCES

Rapid fire: 5 sources + how they are graded + VIBEINT.

OSINT · HUMINT · SIGINT · GEOINT · CHIS

OSINT	Open Source: forums, social networks, leaks, certificate transparency, Shodan/Censys/GreyNoise.
HUMINT	Human: informants, researchers in forums, industry sources.
SIGINT	Signals: network telemetry, passive PDNS, NetFlow. (Government Communications Headquarters (GCHQ).
GEOINT	Exploitation and analysis of imagery and geospatial data
CHIS	Covert Human Intelligence Sources: Person who maintains a relationship (personal or otherwise) with another person in a covert manner.

Admiralty Code: How to grade sources and information

Source reliability

A	Completely reliable
B	Usually reliable
C	Fairly reliable
D	Not usually reliable
E	Unreliable
F	Reliability unknown

Information credibility

1	Confirmed by other sources
2	Probably true
3	Possibly true
4	Doubtfully true
5	Improbable
6	Truth cannot be judged

An "A1" source is reliable and confirmed · an "F6" adds noise, not intelligence.

The system originates in the **British Royal Navy**, in the Naval Intelligence Division (NID). It is used by NATO, FBI, US Army, Europol, INTERPOL, intelligence police forces around the world, and corporate CTI units.

Bonus track: The sixth source nobody cites

There is a sixth source. It is in no manual. I use it every day.

VIBEINT

Information obtained from a hunch or intuition — usually based on prior experience. Mostly unverified, occasionally leads to a real finding.

BLOCK 04 · FRAMEWORKS

Kill Chain · Diamond · MITRE ATT&CK · Pyramid of Pain.

The 4 frameworks don't compete — they compose

CYBER KILL CHAIN

Lockheed Martin · 2011

The 7 phases of an attack.

DIAMOND MODEL

Caltagirone et al. · 2013

Adversary · Capability · Infrastructure · Victim.

MITRE ATT&CK

MITRE · 2013 → present

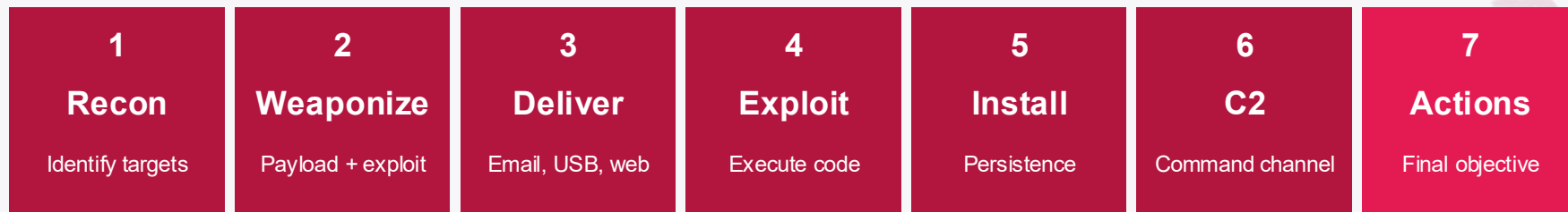
Catalog of TTPs. Lingua franca of the industry.

PYRAMID OF PAIN

David Bianco · 2013

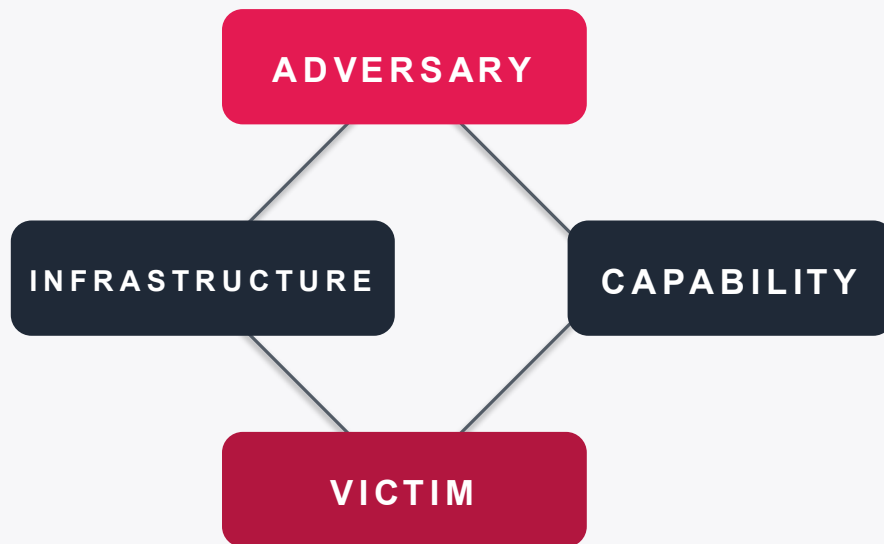
What hurts the attacker: IOCs vs TTPs.

Cyber Kill Chain - 7 phases (Lockheed Martin, 2011)



- **Linear and sequential structure:** Assumes that attacks advance in an Orderly and predictable manner.
- **Perimeter- and malware-oriented approach:** It was designed mainly for external threats.
- **Lack of granularity:** It only identifies high-level phases without detailing specific adversary techniques, procedures or behaviors (TTPs).

Diamond Model - 4 vertices that tell the whole story



Each intrusion event = 4 vertices.

Adversary

— who (intent, attribution).

Capability

— malware, exploits, techniques.

Infrastructure

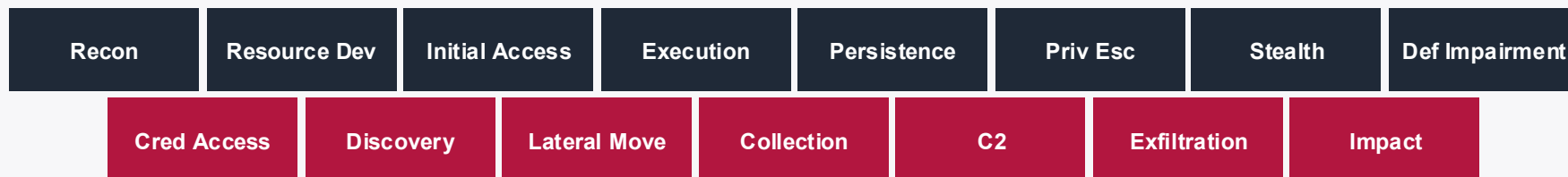
— C2, domains, certificates.

Victim

— who receives the attack.

MITRE ATT&CK · the lingua franca of the industry

15 Tactics · 222 Techniques · 475 Sub-techniques · **v19 (oct 2025)**



v19 (oct 2025) split Defense Evasion into Stealth (hiding) + Defense Impairment (breaking the defense).

Detection Engineering

Map Sigma/SIEM rules to techniques to measure real coverage.

Threat Hunting

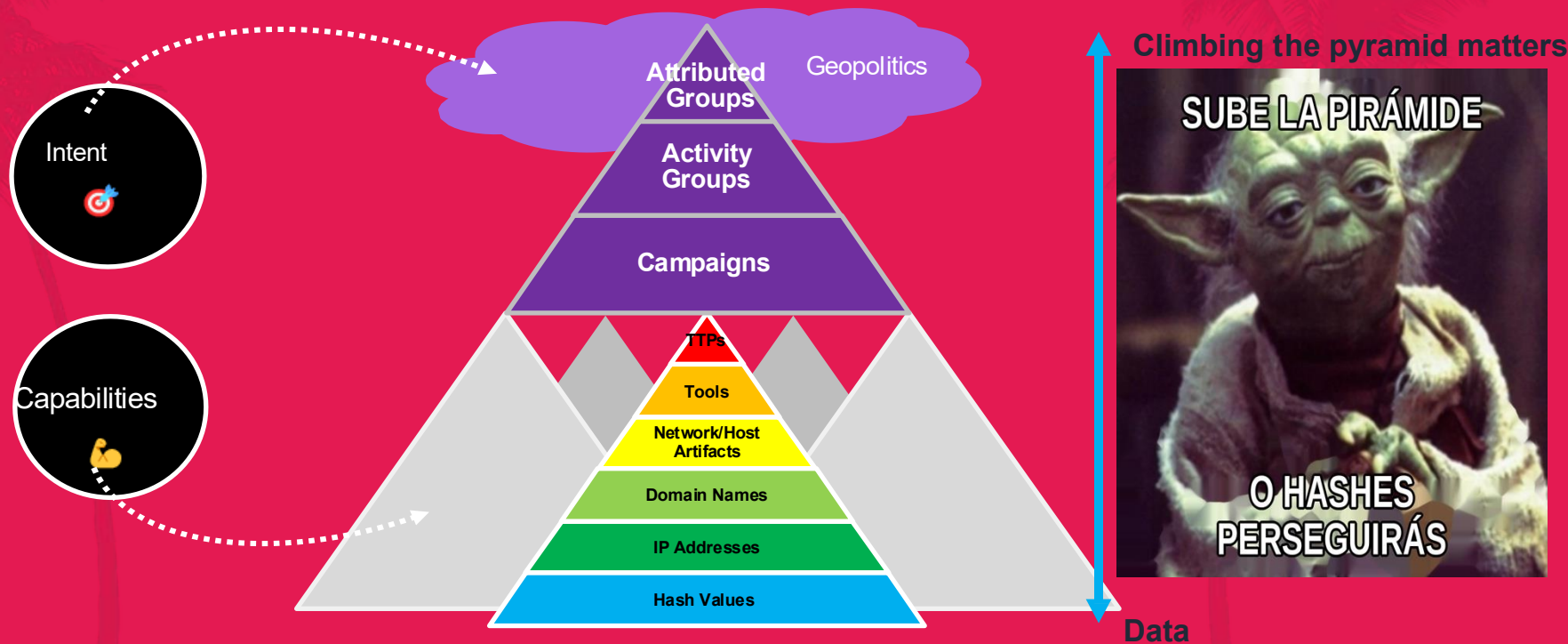
Generate hypotheses about undetected techniques.

Purple Teaming

Emulate real adversaries mapped to concrete techniques.

Warning: mapping everything to ATT&CK does not guarantee real defensive coverage.

Speak to stakeholders in the right language



Extending the Pyramid of Pain

BLOCK 05 · FROM REACTIVE TO PREDICTIVE

PIRs · F3EAD · Attack Trees · threat-informed defense.

CTI Maturity · the 3 stages of the shift

From the talk's subtitle: **"From Reactive to Predictive Approach"**. It is not marketing — it is a maturity path.

REACTIVE	PROACTIVE	PREDICTIVE
<i>I put out fires.</i>	<i>I hunt threats.</i>	<i>I anticipate moves.</i>
TRIGGER The alert reached the SIEM.	TRIGGER The threat hunter's hypothesis.	TRIGGER PIRs + strategic intelligence.
QUESTION What happened? How do we contain it?	QUESTION What are we not seeing?	QUESTION What happens to us in 30/60/90 days?
INDICATOR Hashes · IPs · Domains	INDICATOR TTPs · behaviors	INDICATOR Campaigns · actors · geopolitics
MINDSET Post-mortem forensics	MINDSET Hypothesis-driven	MINDSET Anticipatory · F3EAD
METRIC MTTR (Mean Time To Respond)	METRIC Detection coverage (ATT&CK)	METRIC Time to defensive decision

Going from Reactive to Predictive is not bought — it is built stage by stage.

Why traditional TI falls short

It assumes intelligence arrives before the attack. In practice, it almost never does.

TRADITIONAL TI

Reactive · post-mortem · historical

- Assumes intelligence arrives before the attack
- CVSS says how bad it could be. EPSS says how likely it is to be exploited this week.
- Historical IOCs: it already happened
- Rehashes third-party public disclosures
- Teams drowning in alerts that don't answer: does this affect us today?

REAL WORLD

Weaponization in hours · scanning in minutes

- Exploitation windows in hours after disclosure
- Public PoC accelerates weaponization
- The entire internet scanned in minutes
- Attackers chain vulns + creds + misconfigs
- A 7.0 vuln actively exploited; a 9.8 may never be used

The external severity said 7.0. The internal one was 11.

How do you measure that CTI works?

Four metrics that speak to the CISO, not the SOC.

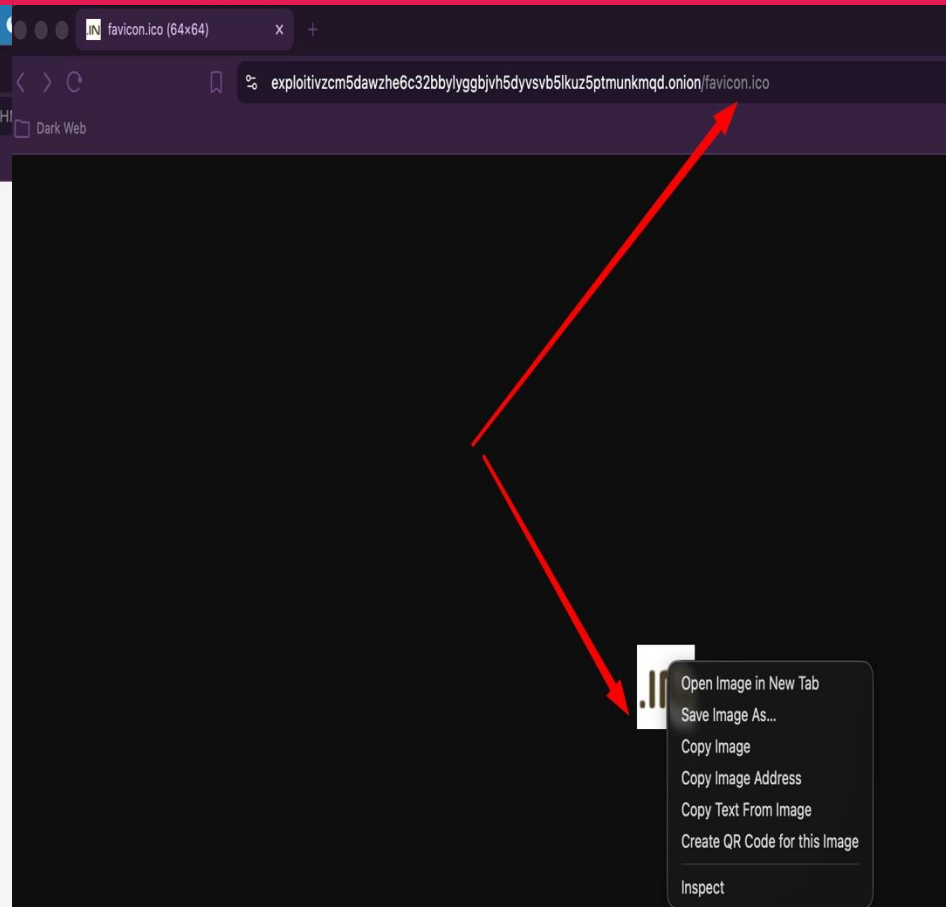
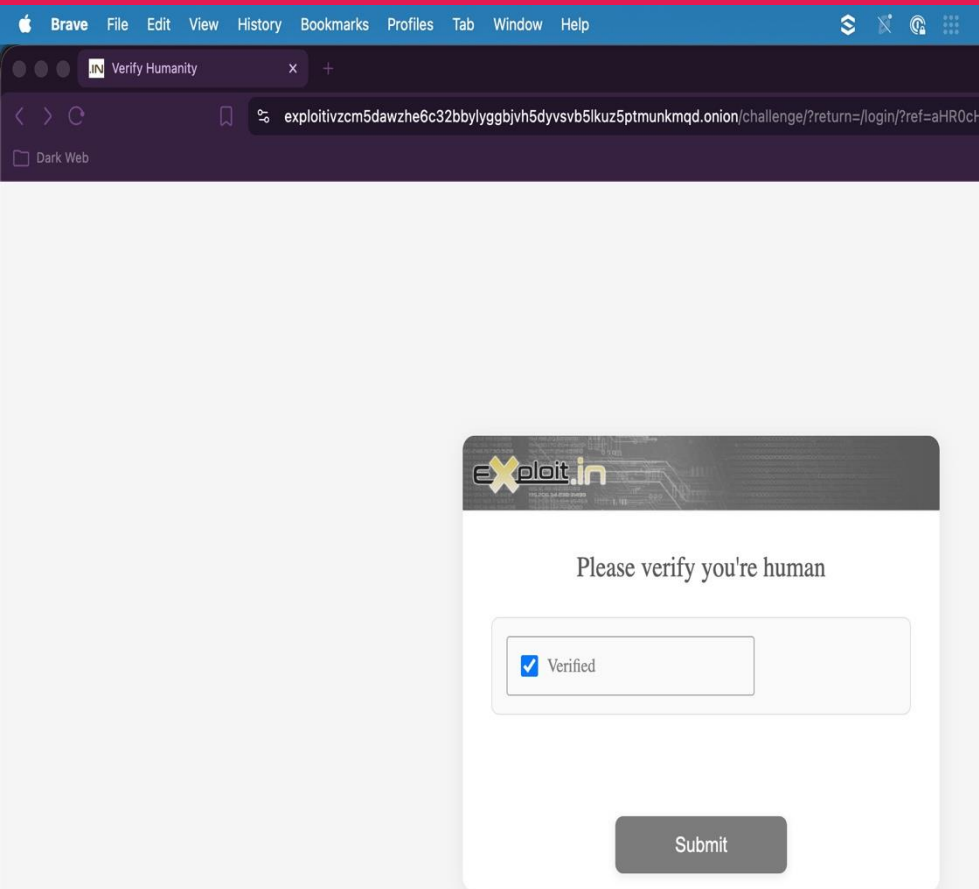
TTPS	PIR	DEC	COV
Time to detect TTP shift	% PIRs answered within SLA	Decisions changed by CTI	ATT&CK coverage critical assets
Days between the adversary changing technique and you detecting it. Ideally, weeks, not months.	Decision-maker questions closed on time. If it is below 80%, CTI is not being CTI.	Reports that triggered concrete action: patch, block, hire, escalate to the board.	% of techniques with detection or prevention over the crown jewels. Not over the whole matrix.

CTI must be able to change business rules in an organization. That is its added value.

BLOCK 06: YOU CAN RUN...

...but you can't hide. Hunting Infrastructure for newbies..

A Dark Web service that thinks it's 100% anonymous leaves artifacts.



A Dark Web service that thinks it's 100% anonymous leaves artifacts.

The screenshot shows a web browser window with the address bar displaying 'favicon-hash.kmsec.uk'. The page has a dark theme and is titled 'Favicon hash generator'. Below the title is a subtitle: 'Get the favicon hash of a website's favicon for Shodan hunting'. The interface is divided into two main sections: 'Retrieve from URL' and 'Upload file'. The 'Retrieve from URL' section has a text input field containing 'https://www.google.com/favicon.ico' and a blue button labeled 'Hash from URL'. The 'Upload file' section has a 'File browser' area with a 'Choose File' button and a file named 'favicon.ico'. Below this is a blue button labeled 'Hash from file'. Underneath the 'Hash from file' button, the text 'Result for file:' is followed by two rows of results: 'favicon_hash' with the value '932673402' and 'md5' with the value 'b8c71f831e9cb09e879122267af9200a'. At the bottom of the page, there are three buttons: 'Search Shodan', 'Search VirusTotal', and 'Search Censys'.

Favicon hash generator

Get the favicon hash of a website's favicon for Shodan hunting

Retrieve from URL
Favicon URL

Hash from URL

Upload file
File browser

Choose File favicon.ico

Hash from file

Result for file:

favicon_hash	932673402
md5	b8c71f831e9cb09e879122267af9200a

Search Shodan **Search VirusTotal** **Search Censys**

The file is uploaded to favicon-hash.kmsec.uk and the algorithm is applied **MurmurHash3**, and a specific HASH is obtained, also MD5

A Dark Web service that thinks it's 100% anonymous leaves artifacts.

forum.exploit.in/login/?ref=aHR0cHM6Ly8wMGJhc2Vob3N0MTFCQVNFmjJlT1NUMzNiYXNlaG9zdDQ0Lw==

exploit.in

Технические работы Jabber-сервера @exploit.im

Войти

У вас нет аккаунта? [Регистрация](#)

Имя пользователя или email-адрес ОБЯЗАТЕЛЬНО

Пароль ОБЯЗАТЕЛЬНО

☒ **Запомнить меня**
Не рекомендуется на общедоступных компьютерах

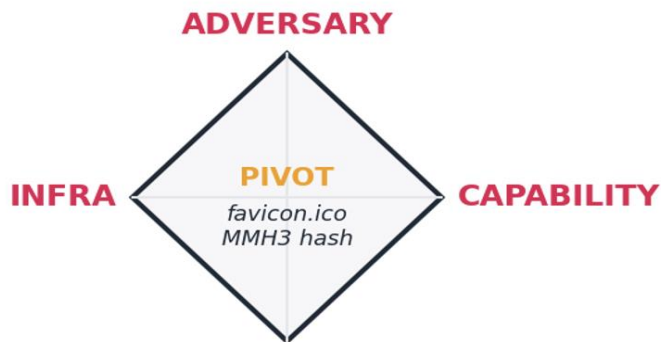
☐ **Войти анонимно**

Войти

[Забыли пароль?](#)

Applying Diamond + ATT&CK to the case

DIAMOND MODEL



ADV. EXPLOIT.IN ops · Moscow, RU

INFRA. forum.exploit.in (NameSilo)
89.39.149.156 · Nginx · + .onion

CAP. Foro · Tor HS · marketplace

VICT. N/A directo (downstream)

MITRE ATT&CK v19

TA0042 · Resource Development

T1583.001 **Domains**
forum.exploit.in · NameSilo

T1583.004 **Server**
89.39.149.156

T1588 **Capability**
marketplace exploits/access

TA0011 · Command and Control

T1090.003 **Multi-hop Proxy**
mirror .onion (Tor)

T1071 **App Layer Protocol**
HTTP/HTTPS · Nginx

Pivot favicon.ico (MMH3) en Shodan/Censys → mismo hash en .onion y clearweb → confirmación de cluster

Why we talk about RMMs: the numbers

Living off the Land is no longer the exception. It is the operational norm of cybercrime.

+277%

YoY increase in RMM abuse
(2025 vs 2024)

24%

1 in 4 incidents involves an
RMM

59.4%

Ransomware entering via
external remote access

51.3%

Big Four concentration: Akira ·
Medusa · Qilin · RansomHub

"Attackers continue to rely on operational efficiency — logging in instead of breaking in, stealing data instead of encrypting it, and exploiting trusted tools instead of complex vulnerabilities."

— Ismael Valenzuela · VP of Labs · Arctic Wolf

Living off the Land · RMMs used by adversaries

TOP TIER · the most cited in recent incidents

ScreenConnect

ConnectWise Control

The most cited of all in incidents.

SimpleHelp

Medusa · DragonForce

A leading player in ransomware campaigns.

AnyDesk

LockBit

Common for post-compromise.

SEEN IN CAMPAIGNS · APTs, ransomware, vishing

Atera

MuddyWater · Royal · BianLian · ALPHV

NetSupport Mgr

RAT legacy · Top 4 Red Canary

PDQ Connect/Deploy

Pivot to deploy other RMMs

BeyondTrust

LogMeIn

GoTo Resolve

N-able

Splashtop

FleetDeck

Ms Quick Assist



3 things you take away

01

CTI = process, not tool.

Start by writing your PIRs. Without PIRs, there is no intelligence.

02

Aim for the top of the pyramid.

Changing a hash is trivial. Changing a TTP is months of rework for the adversary.

03

The adversary also leaves artifacts.

Pivoting + framework + time = attribution. Perfect anonymity does not exist.

Thank you!

Questions, doubts, debate.

References:

Verizon Data Breach Report: <https://www.verizon.com/business/resources/reports/2024-dbir-data-breach-investigations-report.pdf>

State of Vulnerability Response: <https://es.scribd.com/document/1019779413/1730403607-State-of-Vulnerability-Response-Ponemon>

Keys to the Kingdom: <https://techcommunity.microsoft.com/blog/microsoftsecurityexperts/keys-to-the-kingdom-rmm-exploits-enabling-human-operated-intrusions-in-2024%E2%80%934410903>

Understanding the Risks of Remote Monitoring and Management Tools: <https://arcticwolf.com/resources/blog/understanding-the-risks-of-remote-monitoring-and-management-tools/>

Cyber Kill Chains: Strategies & Tactics: https://www.splunk.com/en_us/blog/learn/cyber-kill-chains.html

Daisy-Chaining Rogue RMM Tools: <https://www.huntress.com/blog/daisy-chaining-rogue-rmm-tools>

Projects - Tools: <https://lolrmm.io> - <https://favicon-hash.kmsec.uk>

Authors: @gertjanbruggink